

DevSecOps

Salah satu tujuan DevOps adalah untuk memberikan pembaruan perangkat lunak yang cepat dan berkualitas tinggi. Dan agar perangkat lunak berkualitas tinggi, itu harus memenuhi persyaratan keamanan siber yang ketat. Di situlah keamanan DevOps, atau DevSecOps, masuk. Dalam bacaan ini, Anda akan menjelajahi DevSecOps, pemeriksaan keamanannya, dan ketergantungannya pada otomatisasi.

Apa itu DevSecOps?

DevSecOps adalah perpanjangan dari DevOps yang mengotomatiskan pemeriksaan keamanan di seluruh SDLC untuk mencegah kerentanan pada produk akhir. Kerentanan **adalah** potensi kelemahan, seperti hilangnya enkripsi data, yang dapat dieksploitasi seseorang dalam suatu sistem.

Secara tradisional, pengembang telah menulis sebagian besar kode produksi tanpa mengingat keamanan, dan hanya pada akhir SDLC tim keamanan akan menguji perangkat lunak.

Pendekatan ini berfungsi ketika pembaruan datang hanya beberapa kali setahun, tetapi tim DevOps menghasilkan pembaruan setiap beberapa minggu atau lebih cepat.

Dengan DevSecOps, pengembang memasukkan keamanan ke dalam setiap langkah SDLC. Tim mempertimbangkan dan merencanakan potensi ancaman keamanan sejak dini, dan mereka menguji, memindai, mengaudit, dan meninjau kode selama pengembangan.

Komponen

Komponen utama DevSecOps termasuk tanggung jawab bersama, kecepatan dan kualitas, pemeriksaan keamanan, dan otomatisasi.

Tanggung jawab bersama

Di DevSecOps, semua orang — tim pengembangan, operasi, dan keamanan — berbagi tanggung jawab untuk keamanan.

- Mereka harus memahami keamanan aplikasi dasar dan strategi mitigasi.
- Mereka harus mengikuti pembaruan pada [10 Teratas Proyek Keamanan Aplikasi Web Terbuka \(Open Web Application Security Project Top 10, OWASP\)](#), yang merupakan daftar standar industri mengenai risiko keamanan penting untuk aplikasi web.
- Pengembang harus menyetujui dan mengikuti praktik pengkodean yang aman.

Kecepatan dan kualitas

Masalah keamanan dalam aplikasi membutuhkan waktu dan uang untuk diperbaiki, terutama yang ditemukan di akhir SDLC, dan secara signifikan dapat menunda rilis.

Dengan DevSecOps, tim memperhitungkan keamanan dari tahap perencanaan dan seterusnya, dan mereka mengidentifikasi dan mengatasi masalah keamanan lebih awal dan cepat. Dengan begitu, mereka dapat terus memberikan pembaruan kecil, berkelanjutan, berkualitas tinggi.

Pemeriksaan keamanan

Dengan DevSecOps, perangkat lunak menjalani banyak pemeriksaan keamanan di seluruh SDLC. Mari kita bahas beberapa pemeriksaan standar.

- **Pemodelan ancaman** adalah proses ketika tim mengidentifikasi dan mengkategorikan ancaman keamanan untuk diperhitungkan dalam pengembangan dan dukungan perangkat lunak. Pemodelan ancaman biasanya terjadi selama tahap desain atau perencanaan pengembangan sebelum pengembang menulis kodenya.
- Pemindaian **kerentanan** mengidentifikasi kerentanan dalam aplikasi dan dari pustaka (kumpulan kode yang dapat digunakan kembali) yang menjadi tempat bergantungnya aplikasi. Tim dapat mengotomatiskan penambalan untuk mengatasi kerentanan sesegera mungkin. Dua pemindaian kerentanan yang umum dilakukan adalah pengujian keamanan aplikasi statis dan pengujian keamanan aplikasi dinamis.
- Alat **pengujian keamanan aplikasi statis (SAST)** memindai kerentanan di dalam kode dan pustakanya. “Statis” berarti aplikasi tidak dijalankan; berarti sedang istirahat.
- Alat **pengujian keamanan aplikasi dinamis (DAST)** mendeteksi kerentanan yang dapat diamati di luar kode saat aplikasi berjalan. Untuk melakukannya, alat-alat ini menyimulasikan teknik peretasan nyata seperti injeksi SQL untuk menemukan titik lemah yang dapat dieksploitasi oleh penjahat dunia maya.
- Pemindaian **deteksi rahasia** mencari rahasia yang secara tidak sengaja ditinggalkan oleh pengembang dalam kode atau file konfigurasi. Rahasia adalah kredensial sensitif seperti kata sandi dan kunci enkripsi, dan organisasi harus melindunginya dari kebocoran. Jika rahasia masuk ke dalam basis kode aplikasi, penjahat siber dapat menemukannya.

- **Pengujian unit** adalah pengujian yang mengevaluasi satu komponen, atau unit, dari suatu aplikasi untuk memverifikasi bahwa komponen tersebut bekerja dengan benar. Pengujian ini dijalankan ketika pengembang mengirimkan kode yang baru ditulis untuk diintegrasikan ke dalam basis kode utama perangkat lunak. Di DevSecOps, pengembang merancang pengujian unit tambahan, yang disebut **pengujian unit keamanan**, yang memeriksa masalah keamanan.
- Alat **pemantauan keamanan** memantau aplikasi langsung untuk mendeteksi masalah keamanan seperti serangan siber dan mengirimkan peringatan segera ketika aktivitas tersebut terjadi. Dengan begitu, personel dapat merespons dengan cepat untuk meminimalkan bahaya dan melakukan patch pada aplikasi jika diperlukan.

Otomatisasi

Otomatisasi sangat penting untuk DevOps, dan DevSecOps tidak berbeda.

Alat untuk integrasi berkelanjutan dan pengiriman berkelanjutan (CI/CD) dapat mengotomatiskan pemeriksaan keamanan melalui hampir setiap tahap SDLC, membebaskan semua orang untuk fokus pada tugas lain.

- Alat otomatisasi memverifikasi bahwa kode melewati pengujian unit keamanan dan bahwa dependensi perangkat lunak ada pada patch terbaru mereka.
- Alat SAST mendeteksi kerentanan dalam kode baru sebelum pengembang memasukkannya ke dalam basis kode mereka.
- Alat DAST mengevaluasi pembaruan di lingkungan pra-produksi.
- Alat dapat mengotomatiskan konfigurasi sistem dan layanan, memastikan kepatuhan keamanan dan mengurangi kesalahan manusia.